

Containment and forensics: isolate, capture, eradicate

The incident itself. Stopping the bleeding without destroying the evidence that tells you what happened.

Containment stops the bleeding.
Eradication destroys the evidence. **Do
them in that order.**

The order, and why each step comes where it does

- ◆ **Isolate** – cut the attacker's access and the resource's reach, while leaving the resource running.
- ◆ **Capture** – preserve volatile evidence first, then disk. Copy it somewhere the attacker cannot reach.
- ◆ **Eradicate** – remove the cause. Patch, rebuild, rotate every credential the host could have seen.
- ◆ **Recover** – restore service from a known-good source, then monitor for the attacker returning.
- ◆ Skipping straight to eradicate is the commonest real-world mistake and the commonest wrong answer.

ON THE EXAM

Notice what isolate does not include: stopping, terminating, or rebooting. All three lose evidence you cannot get back.

Isolating an EC2 instance properly

- ◆ **Replace its security groups** with a forensic group with no rules. Egress is denied by default, so outbound stops.
- ◆ **Detach it from the Auto Scaling group**, or the ASG terminates it and replaces it into the same attack.
- ◆ **Deregister it from the target group** so it stops receiving live traffic.
- ◆ **Do not stop or reboot it.** Memory holds the running process, the payload and the keys.
- ◆ Allow one narrow inbound path from the forensic account. Isolation, not disconnection.

ON THE EXAM

A NACL is subnet-wide, so it isolates every instance beside this one too.

Revoking credentials: the details people get wrong

- ◆ Deleting an IAM user's access keys does not end sessions already assumed from a role.
- ◆ Detaching an instance profile stops new credentials. Already-issued ones stay valid until expiry.
- ◆ The real tool is a **Deny on all actions** with **DateLessThan aws:TokenIssueTime**, as **AWSRevokeOlderSessions**.
- ◆ It covers sessions issued before now, plus **~30 seconds ahead** for propagation delay.
- ◆ **aws:TokenIssueTime** exists only for temporary credentials, so it never affects long-term keys.

ON THE EXAM

You cannot revoke a temporary credential. You can only change what it may do.

Two more revocation facts

- ◆ **Identity Center permission set roles cannot be edited in IAM.** Revoke in Identity Center instead.
- ◆ Revocation is **eventually consistent**. An attacker with admin can detach your deny policy mid-propagation.
- ◆ For a fully compromised account, **move it to a quarantine OU** with a restrictive SCP.
- ◆ An SCP applies at the OU level and **the account cannot modify it**. Nothing to detach.
- ◆ Identity-level is surgical. OU-level is decisive. Pick by how far the compromise has spread.

ON THE EXAM

If the attacker holds admin in the account, containment inside it is a race you may lose.

Order of volatility

- ◆ **Memory** first. Running processes, network connections, decrypted secrets, injected code that never touched disk.
- ◆ **Live system state** next – open connections, logged-in sessions, running containers. Collect via Session Manager or SSM Run Command.
- ◆ **Disk** third, as an **EBS snapshot**. Durable, and it will still be there tomorrow.
- ◆ **Logs** last, because CloudTrail, VPC Flow Logs and CloudWatch are already outside the compromised host.
- ◆ Every collection action changes the host. Record what you ran, when, and as whom.

ON THE EXAM

Memory is the only artefact that disappears the moment somebody 'helpfully' stops the instance to be safe.

The snapshot workflow

01

Snapshot

Create an EBS snapshot of each attached volume. The instance keeps running.

02

Copy

Copy the snapshot, re-encrypting with a customer managed key.

03

Share

Share the snapshot and grant the forensic account use of that key.

04

Re-encrypt

The forensic account copies it again under its own key. Now it owns the evidence.

05

Attach

Create a volume and attach it read-only to an isolated forensic workstation.

ON THE EXAM

Five steps, and step two exists for one reason: you cannot share a snapshot encrypted with the default AWS managed key.

The forensic account and chain of custody

- ◆ A **separate account** with its own VPC and keys, and no trust back to workload accounts.
- ◆ Its VPC has **no internet gateway**, so live malware cannot phone home from your workstation.
- ◆ Evidence lands in S3 with **versioning and Object Lock in compliance mode**.
- ◆ **CloudTrail is the chain of custody** – who snapshotted, who copied, who attached, and when.
- ◆ Tag every artefact with the case ID at creation. Retrofitting tags at 4am does not happen.

ON THE EXAM

Object Lock in compliance mode: the module 1 control, doing the same job.

Automated Forensics Orchestrator for Amazon EC2

- ◆ **Named in skill 2.1.4**, so it is examinable. It automates the workflow on the last two slides.
- ◆ **Not a managed service you enable.** An AWS Solutions implementation you deploy with the CDK.
- ◆ Built from **Step Functions, Lambda and SSM documents**. Latest release **1.3.2, April 2026**.
- ◆ Covers **EC2 and EKS**, and **triggers from Security Hub custom actions** – a hard dependency.
- ◆ You build the **forensic AMI**. Reference cost about **\$235 per month**.

ON THE EXAM

Exam answer: the automated EC2 and EKS forensics pattern. Reality: a repo you deploy and own.

Eradicate and recover

- ◆ **Rebuild, do not clean.** You cannot prove you removed everything from a host someone else controlled.
- ◆ **Rotate every credential the host could have seen** – instance role, database passwords, secrets.
- ◆ Fix the entry point. Patching one instance leaves the rest of the fleet as it was.
- ◆ Restore from a backup taken **before** the compromise – which is why the start time matters.
- ◆ Persistence usually lives in an IAM user, a Lambda or a role trust policy, not the host.

ON THE EXAM

The blast radius question is 'what credentials did that host hold', not 'what was on that disk'.

GuardDuty raises UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration. An EC2 instance role's credentials are being used from an IP address outside AWS. The instance is part of a production Auto Scaling group.

The responder immediately detaches the instance profile from the instance. Fifteen minutes later, CloudTrail shows the same external IP still successfully calling s3:GetObject with those credentials.

Why do the credentials still work, and what stops them?

- A The instance profile detach failed silently; retry it and the credentials stop immediately
- B Already-issued session credentials remain valid until expiry; attach a Deny conditioned on aws:TokenIssueTime
- C The attacker has created their own IAM user; delete it and the access stops
- D CloudTrail is showing cached events from before the detach; no further action is needed

◆ PAUSE AND DECIDE

Why do the credentials still work, and what stops them?

- A

The detach failed; retry it

Detaching worked. It stops new credentials being vended to the instance and has no effect on credentials already in the attacker's hands.
- B

Sessions stay valid until expiry; deny on `aws:TokenIssueTime`

Correct. You cannot revoke a temporary credential, only change what it may do. The Deny invalidates every session issued before now.
- C

The attacker created an IAM user

Possible as a separate persistence mechanism and worth checking. It does not explain calls succeeding with the instance role's credentials.
- D

CloudTrail is showing cached events

CloudTrail records calls as they happen. Successful `GetObject` events fifteen minutes later mean successful calls fifteen minutes later.

THE SIGNAL

Detaching the profile controls the supply of credentials. It does nothing about the ones already handed over.

A compromised EC2 instance in a shared subnet is running an unknown process that is exfiltrating data. The instance shares its subnet with fourteen unrelated production instances. Forensics will need memory as well as disk.

A junior engineer proposes stopping the instance immediately to halt the exfiltration, then snapshotting its volumes once it is safely stopped.

What should the team do instead?

- ☐ A Add a DENY rule to the subnet's network ACL blocking all outbound traffic
- ☐ B Terminate the instance and let the Auto Scaling group replace it from the current AMI
- ☐ C Replace its security groups with an empty forensic group, detach it from the ASG, and leave it running
- ☐ D Reboot the instance into single-user mode and collect artefacts from the console

◆ PAUSE AND DECIDE

What should the team do instead?

A DENY rule on the subnet's network ACL

NACLs are subnet-wide. This isolates the compromised instance and the fourteen unrelated production instances beside it.

C Empty forensic security group, detach from ASG, leave running

Correct. Egress stops because no rule permits it, memory survives because the instance keeps running, and the ASG cannot terminate what it no longer manages.

B Terminate and let the ASG replace it

Destroys memory and disk together, and replaces it from the same AMI – so if the entry point was in that image, the replacement is identical.

D Reboot into single-user mode

A reboot loses memory just as a stop does, and the proposal was to preserve memory. It also assumes console access to a host you do not trust.

THE SIGNAL

The junior engineer's instinct is right and their mechanism is wrong. Stopping halts the exfiltration and destroys half the evidence.

During an investigation, an analyst snapshots the volumes of a compromised instance in the production account and shares the snapshots with the dedicated forensic account. The volumes were encrypted with the default EBS encryption key.

The share appears to succeed, but the forensic account cannot create a volume from the snapshot. There is no obvious permissions error on the snapshot itself.

What is the cause, and what is the correct approach?

- ☐ A Snapshots cannot be shared across accounts; copy the data to S3 and share the bucket instead
- ☐ B The forensic account needs `ec2:CreateVolume` added to its role; add the permission and retry
- ☐ C Snapshot sharing requires both accounts to be in the same AWS Organization; enable RAM sharing
- ☐ D Snapshots under the AWS managed key cannot be shared; copy re-encrypting with a customer managed key and grant that key

◆ PAUSE AND DECIDE

What is the cause, and what is the correct approach?

- A

 Snapshots cannot be shared; use S3 instead
They can be shared. This would also mean mounting and copying a compromised filesystem, which alters it – exactly what forensics avoids.
- B

 Add ec2:CreateVolume to the forensic role
The permission is necessary and not the blocker. Without access to the key, the forensic account cannot decrypt the snapshot no matter what IAM allows.
- C

 Both accounts must be in the same Organization
Invented. Snapshot sharing works across any accounts you nominate. Organization membership is not a requirement, and RAM does not share EBS snapshots.
- D

 Copy under a customer managed key and grant that key
Correct. Nobody can be granted use of the default AWS managed key, so the snapshot must be re-encrypted under a key whose policy you control.

THE SIGNAL

'Encrypted with the default EBS key' is the whole question. That sentence appears in the scenario for exactly one reason.

A security manager has read that AWS offers Automated Forensics Orchestrator for Amazon EC2. She asks her team to enable it in the console this week so that the next compromised instance is captured automatically, and has allocated no engineering time.

The team currently uses GuardDuty and Amazon Detective. Security Hub has never been enabled. There is no forensic AMI.

What should the team tell her?

- ☐ A It is an AWS Solutions implementation deployed with the CDK, depends on Security Hub, and needs a forensic AMI built first
- ☐ B It can be enabled from the GuardDuty console once Runtime Monitoring is active
- ☐ C It is included with Amazon Detective and only needs a delegated administrator designating
- ☐ D It is a managed service; enable it in the console and designate a forensic account

◆ PAUSE AND DECIDE

What should the team tell her?

- A

AWS Solutions implementation, CDK-deployed, needs Security Hub and a forensic AMI

Correct. It is a deployable reference implementation built from Step Functions, Lambda and SSM documents, triggered by Security Hub custom actions.
- B

Enable it from GuardDuty with Runtime Monitoring

Runtime Monitoring gives process-level visibility inside instances. It has no relationship to the Orchestrator, which is not a GuardDuty feature.
- C

Included with Amazon Detective

Detective investigates, building graphs from existing findings and logs. It captures no artefacts and does not include the Orchestrator.
- D

A managed service you enable in the console

The answer the name invites, and the reason this question exists. There is no console switch, because there is no service to switch on.

THE SIGNAL

The exam may well name it as the automated EC2 and EKS forensics answer. Knowing what it actually is stops you promising a week's work.

Five things to carry forward

- ◆ **Isolate, capture, eradicate, recover.** Stopping an instance is eradication in disguise.
- ◆ **You cannot revoke a temporary credential** – only deny it via `aws:TokenIssueTime`.
- ◆ **A security group isolates one instance. A NACL isolates the subnet.**
- ◆ **AWS managed key snapshots cannot be shared.** Copy under a CMK, then grant the key.
- ◆ **Automated Forensics Orchestrator is a CDK deployment**, and Security Hub is a hard dependency.

ON THE EXAM

Next: four compromises worked end to end, from a leaked key to a malicious insider.